



École Nationale Supérieure d'Informatique et d'Analyse des Systèmes – RABAT

Rapport de Stage de 2ème Année

Filière Génie Logiciel

Développement d'une Application Web Sécurisée pour la Gestion des Appels d'Offres

---

Réalisé au sein de : **N+ONE DATACENTERS, Casablanca**

Période : **06 août – 06 septembre 2025**

Réalisé par :

Anas Madani

Encadré par :

M. Ayoub Amellaln (N+ONE)
M. Amine El Mahi (N+ONE)

Année universitaire 2024/2025

Dédicace

À ma mère. Ton amour, ta patience et ta confiance m'ont accompagné à chaque étape de ce travail. Tu as toujours été ma source de tendresse et de force. Que Dieu te protège et t'accorde santé, paix et longue vie.

À mon père. Ton sens du devoir, ta discrétion et ta présence solide m'ont transmis la rigueur et le courage. Merci pour tous tes sacrifices. Que Dieu te préserve et t'accorde une vie paisible et épanouie.

À mes frères et à ma sœur. Vous êtes bien plus qu'une famille : vous êtes mes repères et mes complices. Merci pour votre affection, vos encouragements et votre confiance sans faille.

À mon oncle Idriss. Pour ta gentillesse, tes conseils et ta présence. Merci d'avoir cru en moi.

À ma famille et à mes amis proches. Merci pour votre soutien constant, vos mots réconfortants et votre bienveillance. Chacun de vous, à sa manière, a contribué à ce projet.

Anas

Remerciements

Je tiens d'abord à remercier mes encadrants chez **N+ONE DATACENTERS**, **M. Ayoub Amellaln** et **M. Amine El Mahi**, pour leur confiance, leur disponibilité et leurs conseils tout au long de ce stage. Merci de m'avoir guidé simplement et avec bienveillance, et de m'avoir offert un cadre de travail agréable et motivant.

Je remercie aussi le corps enseignant de l'**ENSIAS** pour la formation solide qu'il m'a donnée pendant ces deux ans, et tout particulièrement les enseignants de la filière Génie Logiciel.

Enfin, merci à toute l'équipe de **N+ONE DATACENTERS** pour leur accueil chaleureux et pour avoir rendu mon intégration facile dès le premier jour.

Résumé

Ce rapport présente le développement d'une application web sécurisée de gestion des appels d'offres, réalisé lors d'un stage d'un mois au sein de **N+ONE DATACENTERS** à Casablanca. Le projet répond à un besoin concret : remplacer un processus fragmenté (emails, Excel, partages réseau) par une solution centralisée, traçable et sécurisée.

L'application repose sur une architecture monolithe modulaire (**Django REST Framework** côté backend, **React.js** côté frontend) déployée via **Docker Compose** avec un proxy Nginx en HTTPS. Elle couvre l'intégralité du cycle de vie d'un appel d'offres : de la création au brouillon jusqu'à l'attribution du marché, en passant par la publication, la collecte des soumissions et l'évaluation des candidats.

Les principales fonctionnalités de sécurité implémentées sont : l'authentification **JWT** avec access token en mémoire et refresh token en cookie `httpOnly` scopé, le contrôle d'accès basé sur les rôles (**RBAC**) à quatre niveaux (ADMIN, MANAGER, ANALYST, VIEWER), le chiffrement sélectif **AES-256-GCM** des documents sensibles, et un journal d'audit complet. Un portail public isolé permet aux sociétés externes de déposer leurs propositions sans compte utilisateur, avec rate limiting et vérification des deadlines côté serveur.

Un pipeline d'intégration continue (GitHub Actions) exécute automatiquement les tests pytest et le lint flake8 à chaque push. L'application est déployable en une commande (`docker-compose up`).

Mots-clés : Appels d'offres, Django REST Framework, React.js, JWT, RBAC, AES-256-GCM, Docker Compose, GitHub Actions, Portail public, Audit.

Abstract

This report presents the development of a secure web application for procurement management, carried out during a one-month internship at **N+ONE DATACENTERS** in Casablanca. The project addresses a concrete need : replacing a fragmented process (emails, Excel, shared drives) with a centralized, traceable, and secure solution.

The application is built on a modular monolith architecture (**Django REST Framework** backend, **React.js** frontend) deployed via **Docker Compose** with an Nginx HTTPS proxy. It covers the complete procurement lifecycle : from draft creation to contract award, through publication, submission collection, and candidate evaluation.

The main security features implemented are : **JWT authentication** with access token in memory and refresh token in a scoped `httpOnly` cookie, four-level **role-based access control** (RBAC), selective **AES-256-GCM encryption** of sensitive documents, and a comprehensive audit log. An isolated public portal allows external companies to submit proposals without an account, with IP-based rate limiting and server-side deadline enforcement.

A continuous integration pipeline (GitHub Actions) automatically runs pytest tests and flake8 lint on every push. The application deploys in a single command (`docker-compose up`).

Keywords : Procurement management, Django REST Framework, React.js, JWT, RBAC, AES-256-GCM, Docker Compose, GitHub Actions, Public portal, Audit log.

Liste des abréviations

AES	Advanced Encryption Standard
API	Application Programming Interface
CI	Continuous Integration
CORS	Cross-Origin Resource Sharing
CRUD	Create, Read, Update, Delete
DRF	Django REST Framework
GCM	Galois/Counter Mode
HTTP	HyperText Transfer Protocol
HTTPS	HyperText Transfer Protocol Secure
JWT	JSON Web Token
MIME	Multipurpose Internet Mail Extensions
ORM	Object-Relational Mapper
PDF	Portable Document Format
RBAC	Role-Based Access Control
REST	Representational State Transfer
SPA	Single Page Application
SQL	Structured Query Language
TLS	Transport Layer Security
UUID	Universally Unique Identifier
XSS	Cross-Site Scripting

Table des matières

Liste des abréviations **4**

Liste des figures **7**

Liste des tableaux **8**

Introduction Générale **1**

1 Cahier des Charges **2**
1.1 Présentation de l'organisme d'accueil . . . 2
1.1.1 Offres de la société N+ONE DATACENTERS . . . 3
1.1.2 Empreinte géographique . . . 3
1.1.3 Dates clés de la société N+ONE DATACENTERS . . . 3
1.1.4 Structure interne de l'entreprise . . . 4
1.1.5 Partenaires de l'entreprise . . . 5
1.2 Présentation du sujet . . . 5
1.2.1 Les appels d'offres . . . 5
1.2.2 Les acteurs du système . . . 5
1.2.2.0.1 Acteurs internes . . . 6
1.2.2.0.2 Acteurs externes . . . 6
1.3 Analyse des besoins . . . 6
1.3.1 Besoins fonctionnels . . . 6
1.3.2 Besoins non-fonctionnels . . . 6
1.4 Évaluation et justification de la solution . . . 7
1.4.1 Étude de l'existant . . . 7
1.4.2 Critique de l'existant . . . 7
1.4.3 Justification du développement sur mesure . . . 7
1.4.3.0.1 Estimation des coûts d'infrastructure . . . 8
1.5 Conclusion . . . 8

2 Analyse, Conception et Architecture **9**
2.1 Choix technologiques . . . 9
2.2 Conduite du projet . . . 10
2.2.1 Méthodologie adoptée . . . 10
2.2.2 Planification et backlog . . . 10
2.2.2.1 Backlog produit . . . 10
2.2.2.2 Diagramme de Gantt . . . 11
2.2.3 Déroulement des sprints . . . 12
2.2.3.1 Bilan des sprints . . . 12
2.2.4 Gestion des risques . . . 12
2.3 Modélisation des besoins . . . 13
2.3.1 Diagramme de cas d'utilisation . . . 13
2.3.2 Diagramme d'activité – Cycle de vie d'une offre . . . 14
2.4 Architecture de la solution . . . 15
2.4.1 Vue globale . . . 15
2.4.2 Monolithe modulaire vs microservices . . . 16
2.4.3 Services Docker Compose . . . 16
2.5 Conception détaillée . . . 17
2.5.1 Modèle de données . . . 17

2.5.2 Conception de l'API REST . . . 18
2.5.3 Architecture de sécurité . . . 18
2.5.3.1 Authentification JWT . . . 18
2.5.3.2 Contrôle d'accès basé sur les rôles (RBAC) . . . 20
2.5.3.3 Chiffrement AES-256-GCM . . . 20
2.5.3.4 Diagramme de séquence – Soumission portail public . . . 20
2.6 Conclusion . . . 22

3 Réalisation et Mise en Œuvre 23
3.1 Environnement de développement . . . 23
3.1.1 Outils utilisés . . . 23
3.1.2 Structure du projet . . . 23
3.1.3 Pipeline d'intégration continue . . . 24
3.2 Implémentation du backend . . . 25
3.2.1 Authentification et RBAC . . . 25
3.2.2 Gestion des offres et machine à états . . . 25
3.2.3 Documents et chiffrement AES-256-GCM . . . 26
3.2.4 Portail public . . . 26
3.2.5 Audit et notifications . . . 26
3.3 Implémentation du frontend . . . 27
3.3.1 Gestion de l'authentification . . . 27
3.3.2 Routing protégé par rôle . . . 27
3.3.3 Portail public . . . 27
3.4 Interfaces et fonctionnalités . . . 27
3.4.1 Tableau de bord . . . 27
3.4.2 Liste et filtrage des offres . . . 27
3.4.3 Détail d'une offre . . . 28
3.4.4 Formulaire de création d'offre . . . 28
3.4.5 Évaluation d'une soumission . . . 28
3.4.6 Portail public . . . 28
3.4.7 Journal d'audit . . . 28
3.4.8 Rapport PDF . . . 28
3.5 Tests et validation . . . 31
3.5.1 Tests automatisés . . . 31
3.5.2 Résultats CI . . . 31
3.5.3 Tests manuels . . . 31
3.6 Conclusion . . . 31

Conclusion 33
3.6.0.0.1 Isolation du portail public . . . 33
3.6.0.0.2 Chiffrement sélectif . . . 33
3.6.0.0.3 Pipeline CI . . . 33

4 docker-compose.yml 35

5 Exemple d'entrée AuditLog 37

6 Manuel utilisateur 38

7 Résultats du pipeline CI 39

Table des figures

1.1 Logo de l'entreprise N+ONE DATACENTERS 2
1.2 Logo de OneCloud 2
1.3 Principaux services proposés par N+ONE DATACENTERS 3
1.4 Présence et projets d'expansion de N+ONE DATACENTERS 3
1.5 Récapitulatif des dates clés de N+ONE DATACENTERS 4
1.6 Organigramme de N+ONE DATACENTERS 4
1.7 Partenaires de N+ONE DATACENTERS 5
1.8 Cycle de vie d'un appel d'offres 6

2.1 Diagramme de Gantt du projet (6 août – 6 septembre 2025) 11
2.2 Diagramme de cas d'utilisation 14
2.3 Diagramme d'activité : cycle de vie d'une offre 15
2.4 Architecture globale du système 16
2.5 Diagramme entité-relation 17
2.6 Diagramme de séquence : flux d'authentification 19
2.7 Diagramme de séquence : soumission portail public 21

3.1 Pipeline CI GitHub Actions 24
3.2 Tableau de bord principal 27
3.3 Liste des offres avec filtres 28
3.4 Détail d'une offre avec onglets 28
3.5 Formulaire de création d'offre 28
3.6 Évaluation et scoring d'une soumission 29
3.7 Portail public — liste des offres 29
3.8 Formulaire de soumission publique 29
3.9 Journal d'audit 29
3.10 Exemple de rapport PDF généré 30
3.11 Pipeline CI au vert — tous les tests passent 31

Liste des tableaux

1.1 Besoins fonctionnels du système 6
1.2 Comparaison des solutions existantes 7

2.1 Comparaison et justification des choix technologiques 9
2.2 Backlog produit 11
2.3 Registre des risques du projet 13
2.4 Services Docker Compose 16
2.5 Principaux endpoints de l'API 18
2.6 Matrice de contrôle d'accès 20

3.1 Outils de développement 23
3.2 Couverture des tests automatisés 31

Introduction Générale

Dans un contexte économique où la commande publique et les marchés d'entreprise représentent des volumes financiers considérables, la gestion rigoureuse des appels d'offres constitue un enjeu stratégique majeur. Pour les organisations qui publient et évaluent régulièrement ces appels, la qualité du processus détermine directement la compétitivité, la conformité réglementaire et la maîtrise des délais.

Ce stage de deuxième année a été effectué au sein de **N+ONE DATACENTERS**, société spécialisée dans l'hébergement et la gestion d'infrastructures de datacenters, basée à Casablanca au Maroc. D'une durée d'un mois, du 6 août au 6 septembre 2025, il s'inscrit dans le cadre de la formation en Génie Logiciel à l'École Nationale Supérieure d'Informatique et d'Analyse des Systèmes (ENSIAS) de Rabat.

Avant ce projet, la gestion des appels d'offres chez N+ONE reposait sur des outils non spécialisés : échanges par email, suivi par tableurs Excel et stockage de documents sur disques partagés. Cette approche fragmentée engendrait plusieurs problèmes opérationnels : absence de centralisation, risque de dépassement des délais (absence d'alertes automatiques), sécurité insuffisante des documents financiers sensibles, absence de traçabilité des modifications, et surcharge des agents en fin de période de soumission.

Pour répondre à ces besoins, l'objectif principal du stage était de concevoir et développer une **application web sécurisée de gestion des appels d'offres**, couvrant l'intégralité du cycle de vie : de la création d'une offre jusqu'à l'attribution du marché. La solution repose sur une **architecture monolithe modulaire** (Django REST Framework pour le backend, React.js pour le frontend), déployée via **Docker Compose**, avec un accent particulier sur la sécurité : authentification **JWT** avec gestion fine des sessions, contrôle d'accès basé sur les rôles (**RBAC**), chiffrement sélectif **AES-256-GCM** des documents sensibles, et journal d'audit complet. Un portail public isolé permet aux sociétés externes de déposer leurs propositions sans compte utilisateur, avec limitation du taux de requêtes (rate limiting) et vérification des dates limites côté serveur.

Ce rapport s'organise en trois chapitres. Le **premier chapitre** présente le cahier des charges : l'organisme d'accueil, le domaine des appels d'offres, l'analyse des besoins et la justification d'un développement sur mesure. Le **deuxième chapitre** couvre l'analyse, la conception et l'architecture : choix technologiques, planification, modélisation UML et conception détaillée du système. Le **troisième chapitre** décrit la réalisation et la mise en œuvre : implémentation, interfaces utilisateur et résultats des tests de validation.

Chapitre 1

Cahier des Charges

Ce chapitre pose les fondations du projet en présentant le contexte dans lequel il s'inscrit. Il introduit l'organisme d'accueil, définit le domaine des appels d'offres et ses enjeux, puis détaille les besoins fonctionnels et non-fonctionnels du système. Une étude des solutions existantes vient ensuite justifier le choix d'un développement sur mesure.

1.1 Présentation de l'organisme d'accueil

N+ONE DATACENTERS est un acteur majeur dans le domaine des activités Cloud au Maroc et en Afrique. Depuis sa création en 2008, l'entreprise produit et commercialise des services de réseaux, d'hébergement et d'infogérance de systèmes d'information. Elle possède deux centres d'hébergement situés au Maroc, implantés dans différentes zones sismiques afin de garantir une haute disponibilité des données. N+ONE DATACENTERS propose également des espaces et des services de location de ressources informatiques matérielles dans un cadre dédié, ce qui permet, selon les besoins des clients, un hébergement des données avec une gouvernance territoriale assurée.



FIGURE 1.1 – Logo de l'entreprise N+ONE DATACENTERS

Pour compléter son offre et répondre de manière intégrée aux besoins du marché, N+ONE collabore étroitement avec OneCloud, sa division spécialisée dans les services de cloud computing. Tandis que N+ONE se concentre sur l'infrastructure physique avec ses datacenters certifiés Tier III, OneCloud fournit des services cloud publics et privés, ainsi qu'un accompagnement personnalisé des clients dans leurs projets de migration et de transformation cloud. Cette approche hybride permet de combiner efficacement l'hébergement des services legacy en colocation avec les solutions cloud modernes.



FIGURE 1.2 – Logo de OneCloud

1.1.1 Offres de la société N+ONE DATACENTERS

N+ONE DATACENTERS propose des services d'hébergement informatique évolutifs, pratiques et compétitifs, adaptés à chaque client. Grâce à sa double compétence en hébergement et en réseaux, N+ONE offre à ses clients une plateforme hautement fiable et résiliente, disponible 24h sur 24. Cette offre permet à l'entreprise cliente de bénéficier d'une tranquillité d'esprit totale, et de se concentrer sur son cœur de métier et sa stratégie, tandis que N+ONE gère l'ensemble de son infrastructure informatique selon ses besoins.

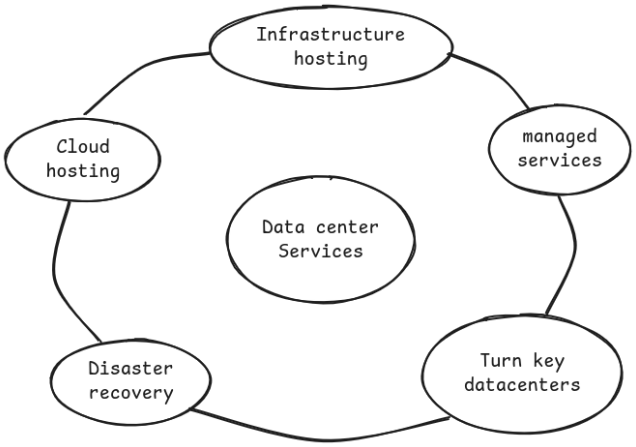


FIGURE 1.3 – Principaux services proposés par N+ONE DATACENTERS

1.1.2 Empreinte géographique

L'entreprise N+ONE DATACENTERS déploie une infrastructure technologique de pointe dans plusieurs régions stratégiques pour accompagner ses clients et partenaires dans leur transformation digitale. Ces initiatives témoignent de son ambition de devenir un acteur clé de l'infrastructure numérique en Afrique et au-delà.

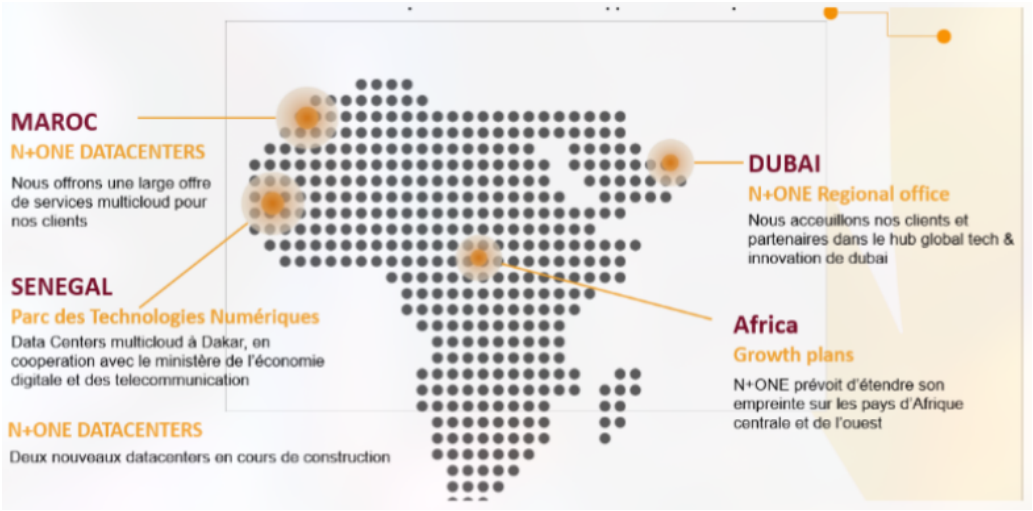


FIGURE 1.4 – Présence et projets d'expansion de N+ONE DATACENTERS

1.1.3 Dates clés de la société N+ONE DATACENTERS

N+ONE a vu le jour en 2008 avec l'ouverture de son premier datacenter à Nouaceur, certifié Tier III en 2014. En 2015, elle a lancé le premier cloud national marocain, OneCloud. Son développement s'est poursuivi avec l'ouverture du datacenter de Settat en 2017 et des centres CMN2 et CMN3 en 2019. En 2020, elle a établi un partenariat avec les trois grands hyperscalers AWS, Azure et Google Cloud, avant le spin-off de OneCloud

en 2021. N+ONE a ensuite élargi ses horizons à l'Afrique de l'Ouest en 2022. En 2024, Oracle est devenu son premier hyperscaler, et l'entreprise a obtenu la certification HDS. Aujourd'hui, N+ONE DATACENTERS met à disposition de ses clients une offre complète multicloud hybride, réunissant la colocation, des services IaaS via OneCloud, et l'intégration avec différents fournisseurs cloud.

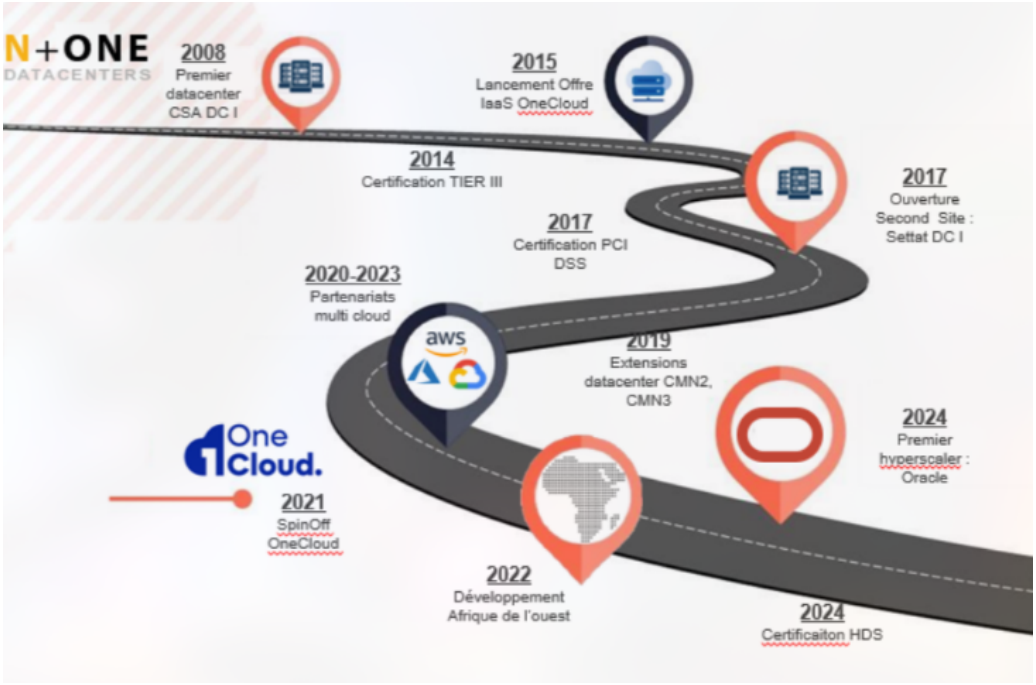


FIGURE 1.5 – Récapitulatif des dates clés de N+ONE DATACENTERS

1.1.4 Structure interne de l'entreprise

L'entreprise bénéficie d'un cadre propice à l'innovation grâce à une équipe jeune et dynamique. Les espaces de travail sont partagés et organisés en espaces de coworking, ce qui permet aux équipes d'évoluer dans un environnement positif favorisant l'échange, la collaboration, l'intelligence collective et l'émulation. Le diagramme ci-dessous présente les départements de l'entreprise ainsi que les relations hiérarchiques entre les différents rôles. Il offre une vision transparente de la structure organisationnelle de N+ONE DATACENTERS, ce qui aide à comprendre le flux de travail et la chaîne de commandement au sein de l'entreprise.

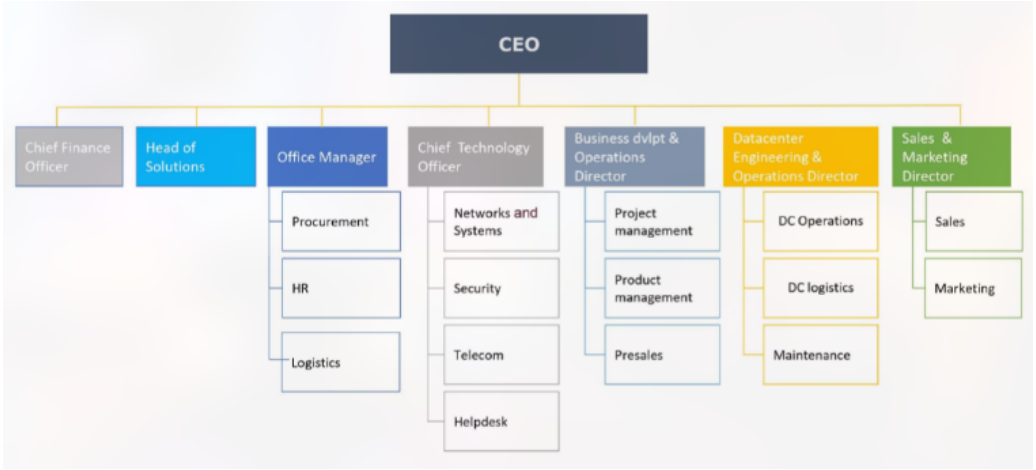


FIGURE 1.6 – Organigramme de N+ONE DATACENTERS

1.1.5 Partenaires de l'entreprise

OneCloud est la division spécialisée dans les services cloud de N+ONE, ce qui permet de tirer parti de la synergie interne pour proposer une offre intégrée en matière de cloud computing. D'autres partenariats sont établis avec des fournisseurs internationaux majeurs (Oracle, AWS, Google, Microsoft) et des spécialistes de la cybersécurité (Cloudflare, Sophos, Fortinet) pour adapter la stratégie autour d'un cloud hybride sur mesure. Dans ce modèle, OneCloud utilise l'infrastructure physique de N+ONE tout en mettant à disposition de sa maison mère son expertise en cloud public, privé et hybride, ainsi que ses compétences en accompagnement à la migration et à la transformation digitale.



FIGURE 1.7 – Partenaires de N+ONE DATACENTERS

1.2 Présentation du sujet

1.2.1 Les appels d'offres

Un appel d'offres est une procédure formalisée par laquelle une organisation (le *maître d'ouvrage*) invite des fournisseurs ou prestataires potentiels à soumettre des propositions commerciales et techniques pour la réalisation d'un marché. Cette procédure garantit la mise en concurrence, la transparence et la traçabilité des décisions d'achat.

Le cycle de vie d'un appel d'offres se décompose en plusieurs phases distinctes, illustrées dans la figure **??** :

1. **BROUILLON (DRAFT)** : l'offre est en cours de rédaction, non visible par les candidats.
2. **PUBLIÉE (PUBLISHED)** : l'offre est ouverte, les sociétés externes peuvent soumettre leurs propositions via le portail public.
3. **ÉVALUATION** : la date limite de soumission est passée ; les responsables évaluent et scorent les candidatures reçues.
4. **ATTRIBUÉE (AWARDED)** : le marché est attribué au candidat retenu.
5. **ANNULÉE (CANCELLED)** : l'offre est interrompue à tout moment avant attribution.

1.2.2 Les acteurs du système

Le système distingue deux catégories d'utilisateurs :

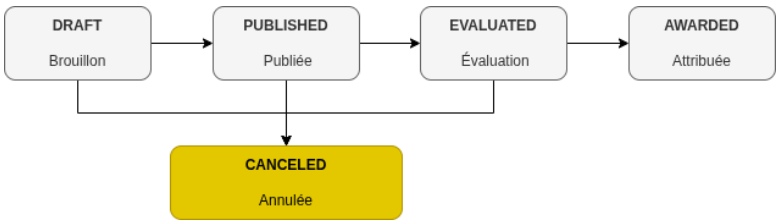


FIGURE 1.8 – Cycle de vie d'un appel d'offres

1.2.2.0.1 Acteurs internes Membres du personnel de N+ONE disposant d'un compte applicatif, répartis en quatre rôles :

- **ADMIN** : administrateur système, gère les comptes utilisateurs et accède au journal d'audit complet.
- **MANAGER** : responsable d'offres, crée et pilote les appels d'offres, attribue les marchés, génère les rapports PDF.
- **ANALYST** : évaluateur, score les soumissions et consulte les dossiers des candidats.
- **VIEWER** : lecteur seul, consulte les offres publiées sans pouvoir modifier quoi que ce soit.

1.2.2.0.2 Acteurs externes Sociétés soumissionnaires accédant uniquement au portail public sans créer de compte. Elles peuvent consulter les offres ouvertes et déposer leurs propositions directement en ligne.

1.3 Analyse des besoins

1.3.1 Besoins fonctionnels

TABLE 1.1 – Besoins fonctionnels du système

Module	Description
Authentification	Connexion sécurisée, déconnexion, rafraîchissement de session
Gestion des offres	Création, modification, publication, transition de statut, annulation
Candidats et soumissions	Enregistrement des candidats, dépôt de soumissions, scoring technique et financier
Documents	Upload multipart, téléchargement sécurisé, chiffrement sélectif
Portail public	Consultation des offres publiées et dépôt de soumissions sans authentification
Notifications	Alertes automatiques : délais approchants, changements de statut, attribution
Rapports	Export PDF d'une offre (synthèse, tableau des scores, candidat retenu)
Audit	Journal des actions sur toutes les ressources (qui, quoi, quand, depuis où)
Administration	Gestion des comptes utilisateurs (création, désactivation, changement de rôle)

1.3.2 Besoins non-fonctionnels

Sécurité Authentification par JWT (token en mémoire, cookie httpOnly), contrôle d'accès basé sur les rôles (RBAC), chiffrement AES-256-GCM des documents sensibles, audit complet, protection contre les injections SQL, HTTPS obligatoire.

Performance Réponses API inférieures à 500 ms pour les listes paginées. Pagination côté serveur (20 offres par page). Chiffrement uniquement sur les documents marqués sensibles pour ne pas pénaliser les uploads standards.

Disponibilité Redémarrage automatique des conteneurs Docker en cas d'échec (`restart: unless-stopped`). Vérifications de santé (*health checks*) sur chaque service.

Traçabilité Toute action d'écriture (création, modification, téléchargement, export, connexion) est enregistrée dans le journal d'audit avec l'adresse IP, l'utilisateur et le contenu des modifications.

Maintenabilité Architecture modulaire (8 applications Django indépendantes), pipeline CI automatique (tests + lint à chaque push), structure de projet documentée.

Reproductibilité Déploiement en une commande (`docker-compose up`). Variables d'environnement pour tous les secrets, aucune valeur en dur dans le code.

1.4 Évaluation et justification de la solution

1.4.1 Étude de l'existant

Plusieurs solutions existent sur le marché pour la gestion des appels d'offres :

TABLE 1.2 – Comparaison des solutions existantes

Solution	**Points forts**	**Limites**	**Adapté ?**
SAP Ariba	Complète, intégration ERP	Coût élevé (licences), délai de déploiement long, sur-mesure impossible	Non
Proactis	Gestion marchés publics	Coût prohibitif pour une PME, rigidité du workflow	Non
OpenProposal / open source	Gratuit	Documentation insuffisante, peu maintenu, pas de support	Non
Excel + partage réseau	Gratuit, familier	Non sécurisé, non traçable, fragile, pas de portail externe	Non
Développement sur mesure	**Adapté exactement aux besoins**	Délai de développement	**Oui**

1.4.2 Critique de l'existant

Aucune des solutions commerciales n'est adaptée au contexte de ce stage pour trois raisons cumulatives. D'abord, le budget non alloué aux licences interdit les solutions payantes. Ensuite, le délai d'un mois exclut tout déploiement et personnalisation de produit tiers. Enfin, le besoin d'un chiffrement sélectif des documents financiers et d'un portail public isolé dépasse les fonctionnalités standard des outils génériques.

La solution Excel actuelle, bien que pratique, expose l'entreprise à des risques réels : perte de données, accès non contrôlé aux offres financières, impossibilité de retrouver l'historique des modifications.

1.4.3 Justification du développement sur mesure

Le développement d'une application web sur mesure est la seule option répondant simultanément à toutes les contraintes :

- Workflow exact du processus N+ONE (statuts, rôles, notifications) ;
- Chiffrement AES-256-GCM intégré nativement ;

- Portail public isolé pour les sociétés externes ;
- Coût nul en licences (stack open source) ;
- Déployable sur l'infrastructure existante de N+ONE.

1.4.3.0.1 Estimation des coûts d'infrastructure En cas de déploiement en production, le coût se limiterait à l'infrastructure serveur : environ 50 à 100 euros par mois sur un serveur cloud (ou nul si déployé sur les serveurs internes N+ONE), contre plusieurs milliers d'euros annuels pour une licence SAP Ariba.

1.5 Conclusion

Ce chapitre a permis de cadrer le projet dans son contexte organisationnel et technique. La présentation de N+ONE DATACENTERS a mis en évidence les besoins concrets d'une entreprise gérant des appels d'offres à volume croissant. L'analyse des besoins a établi les exigences fonctionnelles et non-fonctionnelles auxquelles la solution doit répondre, tandis que l'étude de l'existant a démontré qu'aucune solution du marché ne satisfait simultanément toutes les contraintes identifiées. Ces éléments justifient pleinement le développement d'une application sur mesure, dont la conception et l'architecture sont détaillées dans le chapitre suivant.

Chapitre 2

Analyse, Conception et Architecture

Ce chapitre présente les décisions de conception qui ont guidé le développement du système. Les choix technologiques sont d'abord justifiés, puis la conduite du projet est décrite à travers la méthodologie adoptée et la planification en sprints. La modélisation UML formalise les besoins identifiés au chapitre précédent, avant de détailler l'architecture globale, le modèle de données, la conception de l'API REST et de la couche de sécurité.

2.1 Choix technologiques

Le choix de la stack technique a été guidé par trois critères : la rapidité de développement (délai d'un mois), la maturité des outils (documentation, communauté) et la sécurité intégrée (peu d'extensions nécessaires pour les fonctionnalités critiques).

Table 2.1 – Comparaison et justification des choix technologiques

Couche	**Choix retenu**	**Justification dans le contexte du stage**
Backend	Django + DRF	Stack maîtrisée. L'administration Django et les modules DRF (sérialisation, permissions, pagination) évitent de réimplémenter des fonctionnalités standard, ce qui est décisif sur un délai d'un mois.
Frontend	React.js + Vite	Framework connu, documentation abondante, large choix de composants d'interface. Le choix est pragmatique : utiliser ce qu'on maîtrise plutôt que d'apprendre un nouveau framework en parallèle du développement.
Base de données	PostgreSQL	Standard de fait avec Django. Support natif du type JSON (utile pour `AuditLog.changes`) et de `TIMESTAMPTZ` pour la gestion précise des délais.
Authentification	JWT (simplejwt)	Bibliothèque officielle de l'écosystème DRF, intégrable en quelques heures. La solution couvre le besoin (usage interne, une seule organisation) sans nécessiter un serveur OAuth2 dédié, ce qui était hors du périmètre du stage.
Conteneurisation	Docker Compose	Outil maîtrisé permettant de démarrer les cinq services en une commande. Kubernetes serait pertinent pour un déploiement en production à grande échelle, mais constitue une complexité opérationnelle injustifiée ici.
Proxy	Nginx + HTTPS	Configuration TLS simple et bien documentée. Gunicorn seul ne gère pas le TLS nativement et n'est pas conçu pour être exposé directement.
CI/CD	GitHub Actions	CI gratuite, intégrée au dépôt, sans infrastructure à maintenir. Adaptée à un projet solo avec un seul environnement cible.

Django a été préféré pour son administration intégrée (économie de trois à quatre jours), son ORM qui prévient nativement les injections SQL, et DRF qui fournit sérialisation, permissions et pagination sans code supplémentaire.

PostgreSQL offre un support natif des colonnes JSON (utile pour `AuditLog.changes`), un type `TIMESTAMPTZ` précis pour le suivi des délais, et de meilleures performances sur la recherche textuelle avec l'opérateur `ILIKE`.

Docker Compose permet de démarrer l'ensemble du système (frontend, backend, base de données, proxy, scheduler) en une seule commande, garantissant la reproductibilité entre les environnements de développement et de démonstration.

2.2 Conduite du projet

2.2.1 Méthodologie adoptée

Face à une contrainte de délai d'un mois et à un périmètre fonctionnel initialement estimé mais susceptible d'être affiné au fil des retours, une approche Agile adaptée a été adoptée, inspirée du cadre Scrum tout en tenant compte du contexte d'un développeur solo.

Chaque semaine constituait un sprint d'une durée fixe, avec un livrable démontrable à la fin. En début de sprint, le backlog était revu et priorisé en concertation avec les encadrants ; en fin de sprint, une démonstration informelle permettait de valider les fonctionnalités réalisées et d'ajuster les priorités pour le sprint suivant. Le suivi quotidien des tâches a été assuré via un tableau Kanban personnel organisé en trois colonnes : *À faire*, *En cours*, *Terminé*.

Ce choix a été préféré à une approche cycle en V classique pour deux raisons principales : la nature incrémentale du projet (chaque sprint livrait une couche fonctionnelle complète et testable), et la nécessité de faire valider les choix de sécurité au fur et à mesure plutôt qu'en fin de projet.

2.2.2 Planification et backlog

2.2.2.1 Backlog produit

Les fonctionnalités ont été priorisées selon le modèle MoSCoW (Must-Have, Should-Have, Could-Have), en accord avec les exigences exprimées par les encadrants en début de stage.

TABLE 2.2 – Backlog produit

ID	Priorité	User Story	Sprint	Statut
US-01	Haute	Admin peut créer et gérer les comptes utilisateurs avec rôles	S1	✓
US-02	Haute	Utilisateur se connecte via email/mot de passe, reçoit un JWT	S1	✓
US-03	Haute	Access token rafraîchi automatiquement via cookie httpOnly	S1	✓
US-04	Haute	Manager peut créer un appel d'offres (titre, budget, délais)	S2	✓
US-05	Haute	Manager peut publier, clôturer ou attribuer une offre	S2	✓
US-06	Moyenne	Analyst peut consulter toutes les offres et évaluer les soumissions	S2	✓
US-07	Moyenne	Upload de documents PDF/DOCX associés à une offre	S2	✓
US-08	Haute	Contrôle d'accès RBAC appliqué sur tous les endpoints	S3	✓
US-09	Haute	Documents financiers chiffrés AES-256-GCM à l'upload	S4	✓
US-10	Haute	Journal d'audit enregistrant toutes les opérations d'écriture	S3	✓
US-11	Moyenne	Notifications automatiques générées avant expiration des délais	S3	✓
US-12	Haute	Société externe soumet une offre via portail public sans compte	S4	✓
US-13	Moyenne	Export PDF d'un rapport de synthèse par offre	S4	✓
US-14	Moyenne	Pipeline CI (lint flake8 + pytest) déclenché à chaque push	S4	✓

2.2.2.2 Diagramme de Gantt

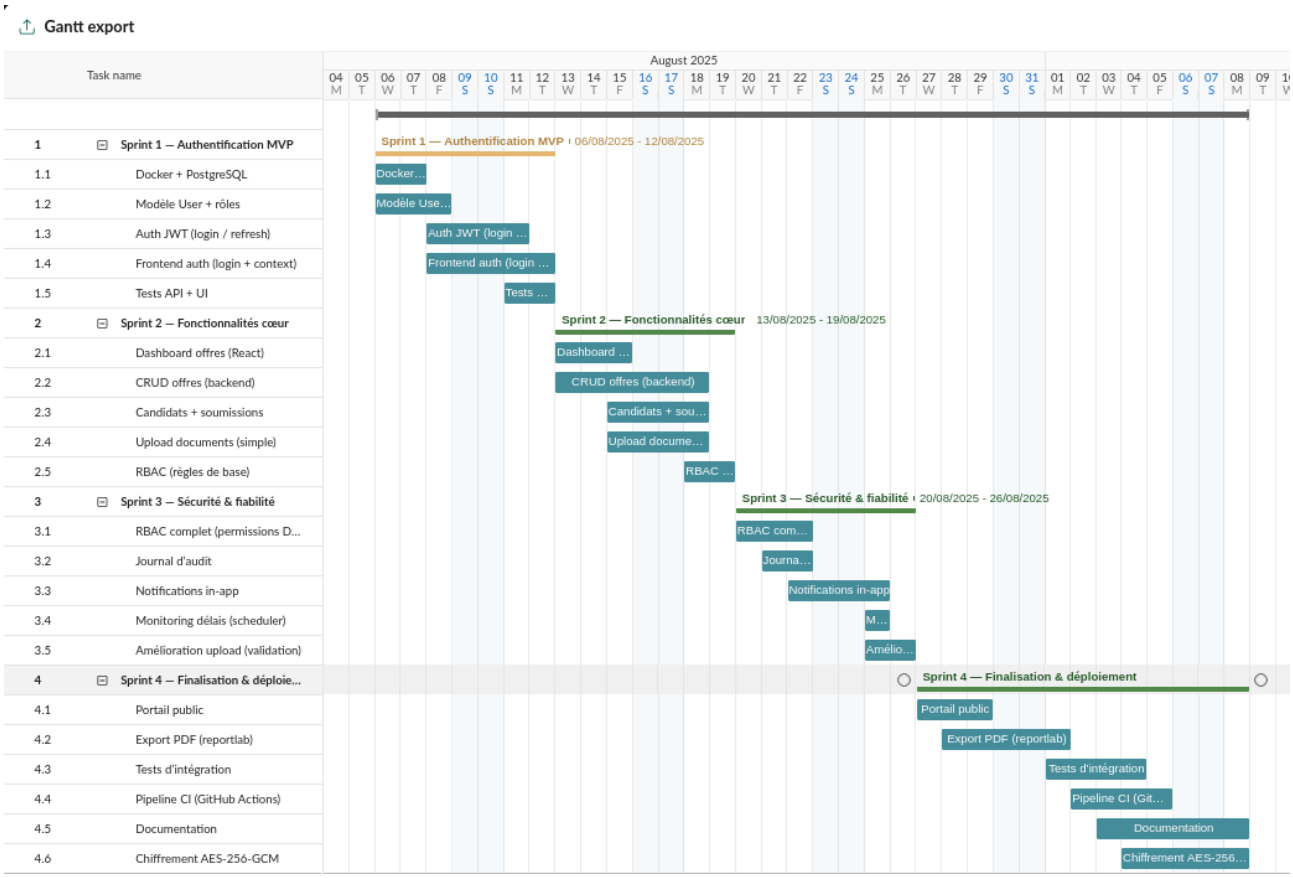


FIGURE 2.1 – Diagramme de Gantt du projet (6 août – 6 septembre 2025)

2.2.3 Déroulement des sprints

Le projet a été découpé en quatre sprints hebdomadaires, chacun centré sur un objectif livrable.

Sprint 1 (6–12 août) — Authentification MVP Mise en place de l'environnement Docker Compose avec PostgreSQL, modélisation de l'entité User avec les quatre rôles, implémentation de l'authentification JWT (login, refresh, logout), développement du frontend d'authentification (formulaire de connexion, `AuthContext`), et tests des endpoints API et de l'interface. Livrable : connexion fonctionnelle bout en bout, accès protégé par token.

Sprint 2 (13–19 août) — Fonctionnalités cœur Développement du dashboard des offres en React, CRUD complet des offres côté backend, gestion des candidats et soumissions, upload de documents, et mise en place des règles RBAC de base. Livrable : un manager peut créer une offre et enregistrer des soumissions ; les rôles sont appliqués sur les routes principales.

Sprint 3 (20–26 août) — Sécurité & fiabilité Finalisation du RBAC avec les permissions DRF sur tous les endpoints, journal d'audit, notifications in-app, monitoring des délais (scheduler), et amélioration de la validation à l'upload (types MIME, taille). Livrable : contrôle d'accès complet, audit actif, alertes de délais fonctionnelles.

Sprint 4 (27 août – 6 septembre) — Finalisation & déploiement Portail public (soumissions sans compte), export PDF des rapports d'offres, chiffrement AES-256-GCM des documents sensibles, tests d'intégration, pipeline CI GitHub Actions, et documentation. Livrable : application complète, sécurisée, testée et déployable en une commande.

2.2.3.1 Bilan des sprints

Sprint 1. La configuration du réseau Docker (communication inter-conteneurs, variables d'environnement) a pris plus de temps qu'estimé. La configuration du cookie httpOnly pour le refresh token a nécessité une recherche sur la gestion des cookies cross-origin avec DRF. Le livrable a été atteint avec un jour de retard, rattrapé en début de sprint 2.

Sprint 2. La complexité de l'upload de documents (validation MIME, gestion des fichiers Django) a occupé une partie significative du sprint. Les règles RBAC de base ont été intégrées en fin de sprint pour sécuriser les routes principales. Les fonctionnalités cœur ont été livrées dans les délais.

Sprint 3. La finalisation du RBAC sur l'ensemble des endpoints a nécessité une revue systématique des permissions DRF. Le scheduler de monitoring des délais a été simplifié : une boucle shell dans un conteneur dédié plutôt qu'une intégration Celery, jugée trop complexe pour le délai disponible. L'amélioration de la validation à l'upload (types MIME, taille maximale) a été ajoutée sans impact sur les fonctionnalités existantes.

Sprint 4. L'intégration d'AES-256-GCM a nécessité une journée de recherche non planifiée sur la bibliothèque `cryptography` (gestion du nonce, format de stockage `nonce || ciphertext || tag`). La configuration du pipeline GitHub Actions (base PostgreSQL de test, variables d'environnement CI) a été achevée dans les deux derniers jours du stage. La documentation a été finalisée en parallèle.

2.2.4 Gestion des risques

Table 2.3 – Registre des risques du projet

Risque	**Probabilité**	**Impact**	**Stratégie de mitigation**
Mauvaise estimation de la durée d'une fonctionnalité complexe	Moyenne	Élevé	Timeboxing strict de deux jours par sous-tâche ; report vers le sprint suivant si dépassé
Instabilité d'une bibliothèque tierce (ex. simplejwt, cryptography)	Faible	Moyen	Vérification des versions LTS et de l'activité des dépôts avant adoption
Perte du code source (panne matérielle, suppression accidentelle)	Faible	Critique	Dépôt Git privé avec push quotidien, branches de sauvegarde hebdomadaires
Évolution du périmètre fonctionnel en cours de sprint	Moyenne	Moyen	Validation du backlog avec le maître de stage en début de chaque sprint
Incompatibilité entre services Docker (version PostgreSQL, réseau)	Faible	Élevé	Tests d'intégration dès le sprint 1 ; health checks sur tous les services

2.3 Modélisation des besoins

2.3.1 Diagramme de cas d'utilisation

Le diagramme de cas d'utilisation (figure 2.2) présente les interactions entre les cinq acteurs du système et les fonctionnalités exposées. Les acteurs internes (Admin, Manager, Analyst, Viewer) s'authentifient via JWT. L'acteur externe (société soumissionnaire) accède uniquement au portail public sans authentification.

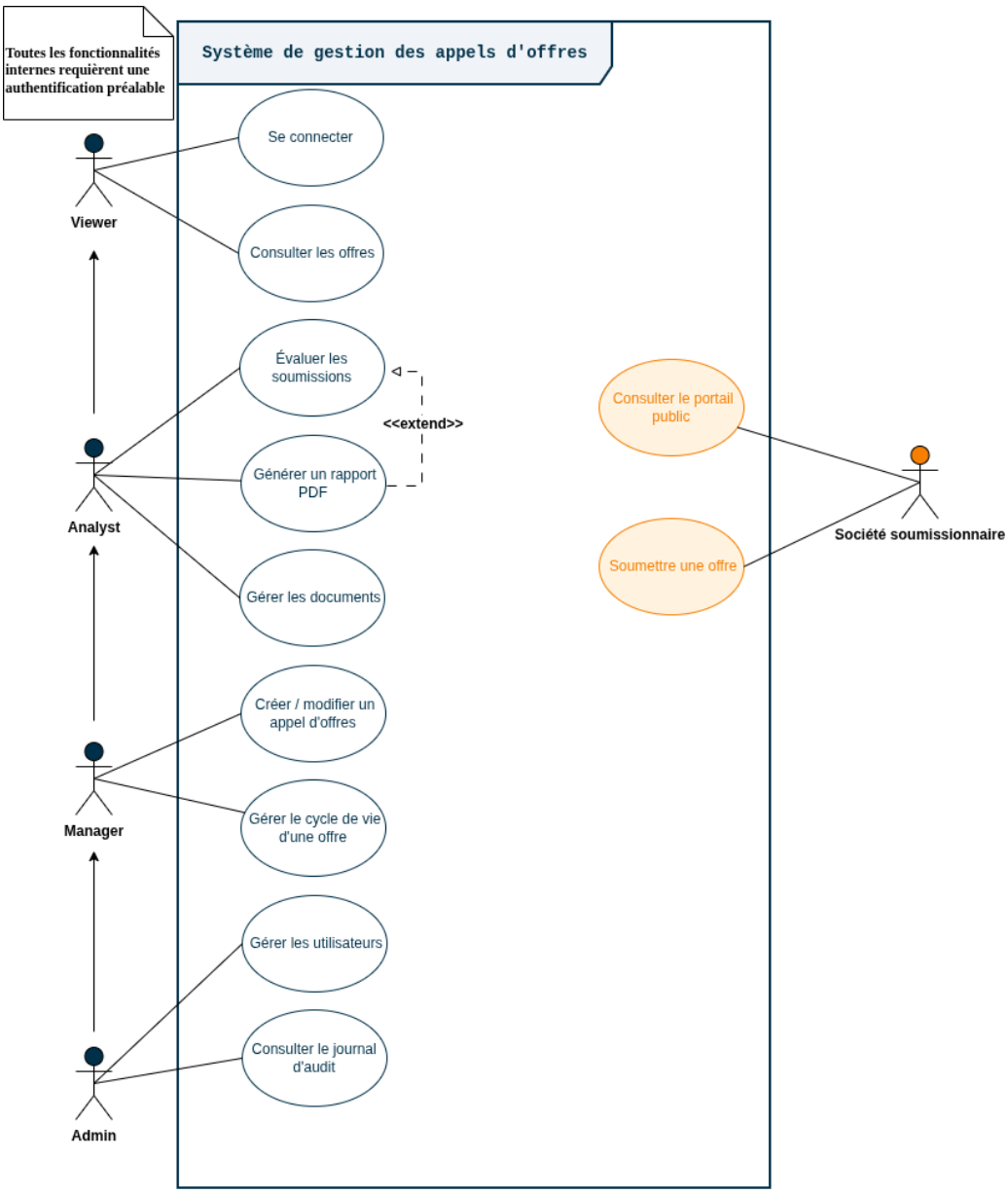


FIGURE 2.2 – Diagramme de cas d'utilisation

2.3.2 Diagramme d'activité – Cycle de vie d'une offre

Le cycle de vie d'une offre est contrôlé côté serveur par la méthode `can_transition_to()` du modèle `OfferCall`. Les transitions autorisées sont :

$$\text{DRAFT} \rightarrow \text{PUBLISHED} \rightarrow \text{EVALUATION} \rightarrow \text{AWARDED}$$

À tout moment avant attribution, une offre peut être annulée (`CANCELLED`) via l'endpoint `POST /api/offers/{id}/cancel`. Toute tentative de transition non autorisée retourne une erreur HTTP 400.

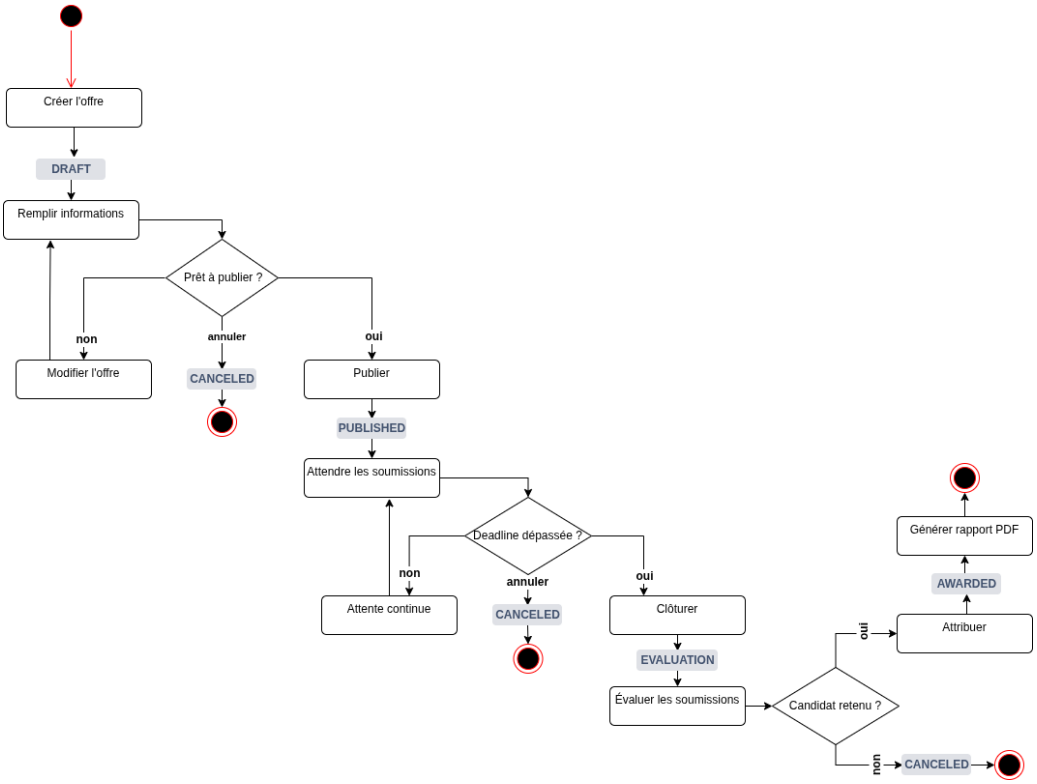


FIGURE 2.3 – Diagramme d'activité : cycle de vie d'une offre

2.4 Architecture de la solution

2.4.1 Vue globale

L'application repose sur une architecture monolithe modulaire : un seul processus Django contenant huit applications indépendantes, déployé derrière un proxy Nginx gérant le TLS.

Le flux d'une requête authentifiée :

1. Le navigateur envoie la requête HTTPS sur le port 443.
2. Nginx termine la TLS et route vers le frontend React (assets statiques) ou vers le backend Django (`/api/*`).
3. Django traite la requête : authentification JWT, vérification du rôle, logique métier, accès PostgreSQL via l'ORM.
4. La réponse remonte par Nginx vers le client.

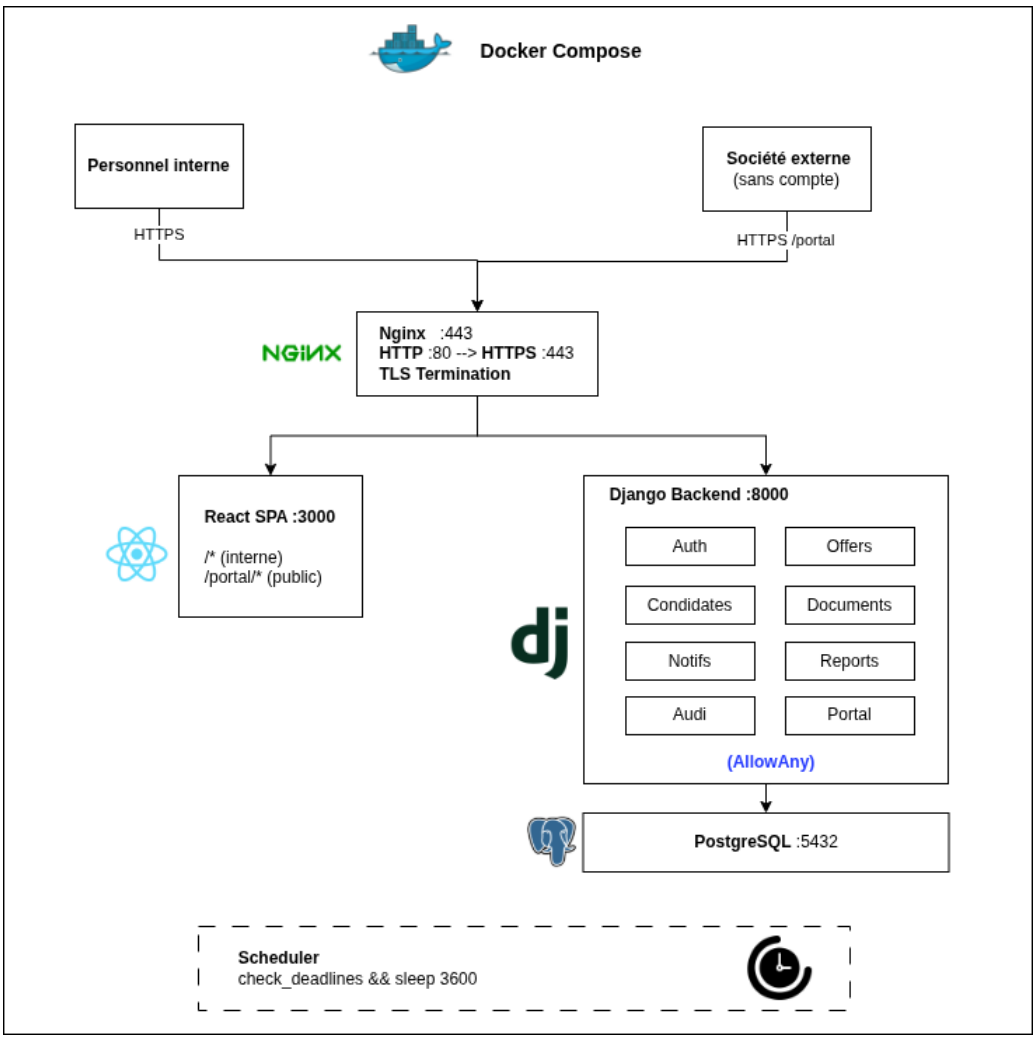


FIGURE 2.4 – Architecture globale du système

2.4.2 Monolithe modulaire vs microservices

Une architecture microservices aurait nécessité une API gateway, la découverte de services, une authentification inter-services et un traçage distribué, ce qui est impossible à développer seul en un mois. Le monolithe modulaire offre la séparation des responsabilités via les frontières des applications Django (chaque application possède ses propres `models.py`, `views.py`, `serializers.py`, `urls.py`), tout en conservant la simplicité opérationnelle (`docker-compose up`).

2.4.3 Services Docker Compose

TABLE 2.4 – Services Docker Compose

Service	Port	Rôle
`db`	5432	PostgreSQL, données persistées sur volume nommé
`backend`	8000	Django + Gunicorn, migrations automatiques au démarrage
`frontend`	3000	React SPA (build statique ou serveur de développement)
`nginx`	80, 443	Proxy inverse, terminaison TLS, redirection HTTP → HTTPS
`scheduler`	–	Boucle `check_deadlines && sleep 3600`

Tous les services disposent de vérifications de santé (health checks). Les services `backend` et `nginx` démarrent uniquement après que `db` soit déclaré sain (`condition: service_healthy`).

2.5 Conception détaillée

2.5.1 Modèle de données

Le modèle de données comprend sept entités principales, représentées dans le diagramme entité-relation (figure 2.5).

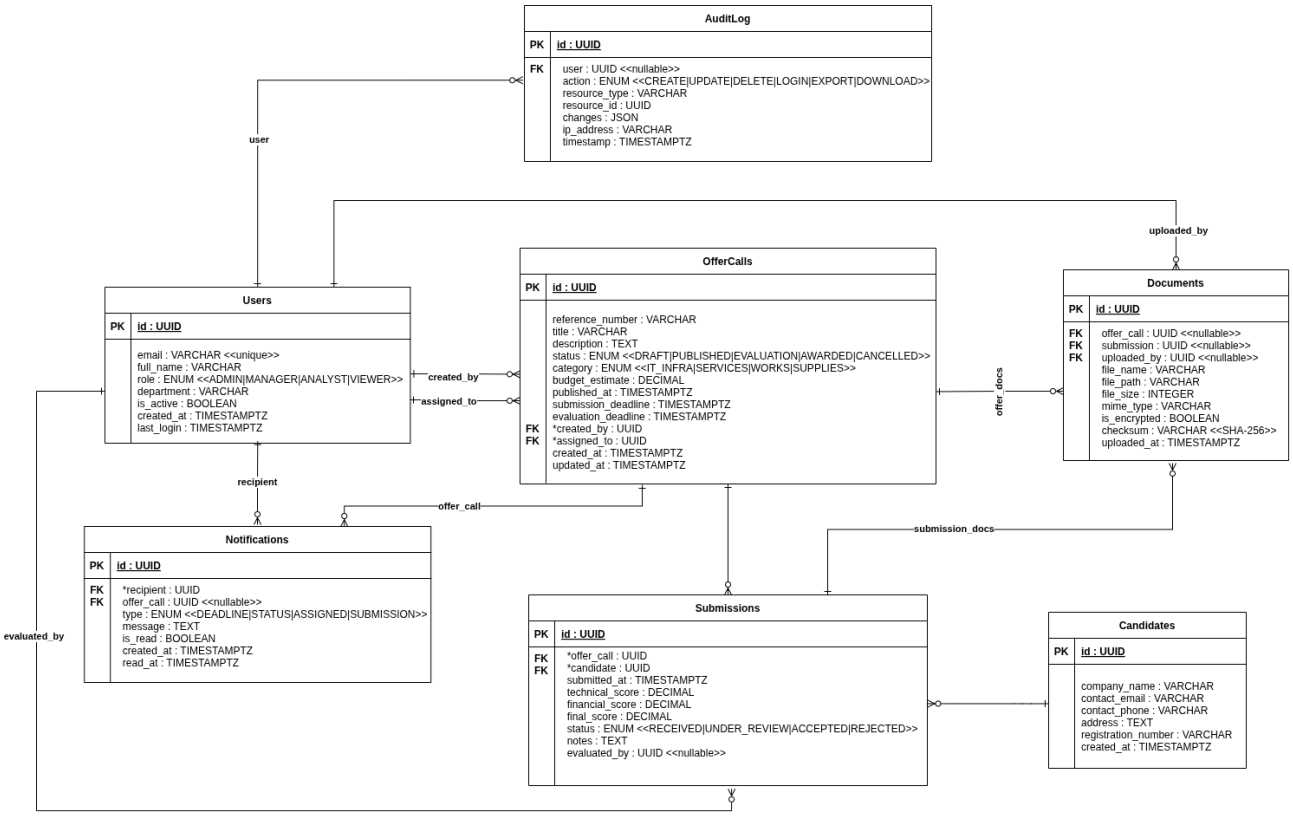


FIGURE 2.5 – Diagramme entité-relation

Les choix de conception notables sont :

UUID comme clé primaire Tous les modèles utilisent `UUIDField` comme clé primaire. Contrairement aux entiers auto-incrémentés, les UUID ne révèlent pas le volume de données et empêchent l'énumération (`/offers/1`, `/offers/2`).

`uploaded_by` nullable Le champ `Document.uploaded_by` est nullable avec `on_delete=SET_NULL`. Les documents déposés via le portail public (sans compte utilisateur) ont ce champ à `NULL`. Les documents uploadés par le personnel ont leur auteur référencé.

Deadlines séparées `OfferCall` possède deux champs distincts : `submission_deadline` (date limite de dépôt pour les candidats) et `evaluation_deadline` (date limite d'évaluation pour les équipes internes). Le scheduler surveille les deux indépendamment.

`AuditLog.changes` en JSON Le champ `changes` stocke un objet JSON arbitraire représentant les modifications apportées à la ressource. Cette approche évite une table de colonnes rigides et s'adapte à n'importe quelle ressource auditée.

2.5.2 Conception de l'API REST

L'API respecte les conventions REST : ressources nommées, méthodes HTTP sémantiques, codes de retour standard. La pagination est systématique sur les listes (`count, next, previous, results`).

TABLE 2.5 – Principaux endpoints de l'API

Endpoint	Méthode	Description
`/api/auth/login/`	POST	Connexion, retourne access token + cookie httpOnly
`/api/auth/refresh/`	POST	Rafraîchit l'access token via le cookie
`/api/auth/logout/`	POST	Blackliste le refresh token, supprime le cookie
`/api/offers/`	GET, POST	Liste paginée, création d'offre
`/api/offers/{id}/`	GET, PATCH	Détail, modification
`/api/offers/{id}/publish/`	POST	DRAFT → PUBLISHED
`/api/offers/{id}/close/`	POST	PUBLISHED → EVALUATION
`/api/offers/{id}/award/`	POST	EVALUATION → AWARDED
`/api/offers/{id}/cancel/`	POST	Annulation (tout statut non terminal)
`/api/documents/upload/`	POST	Upload multipart, chiffrement optionnel
`/api/documents/{id}/download/`	GET	Téléchargement (déchiffrement transparent)
`/api/notifications/unread-count/`	GET	Nombre de notifications non lues
`/api/reports/offers/{id}/export/`	GET	Export PDF d'une offre
`/api/audit/logs/`	GET	Journal d'audit (ADMIN uniquement)
`/api/portal/offers/`	GET	Offres publiées (AllowAny)
`/api/portal/offers/{id}/submit/`	POST	Soumission publique (AllowAny, rate limiting)

Les transitions d'état sont des endpoints POST dédiés (et non une modification PATCH du champ `status`). Cela garantit que la logique de validation de la transition est toujours exécutée côté serveur, quelle que soit la requête entrante.

2.5.3 Architecture de sécurité

2.5.3.1 Authentification JWT

Le schéma d'authentification repose sur deux tokens aux durées de vie différentes : l'access token (15 minutes) et le refresh token (7 jours).

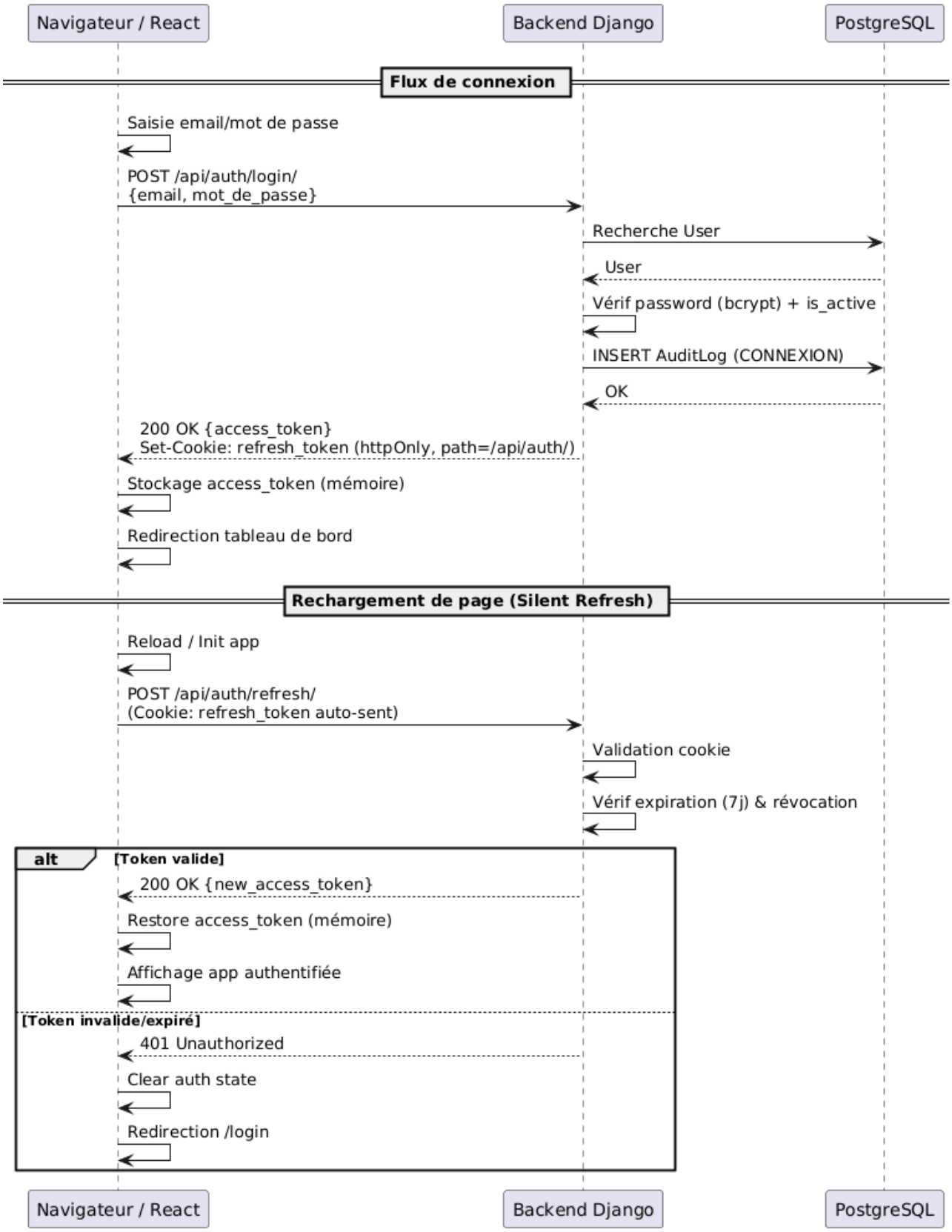


FIGURE 2.6 – Diagramme de séquence : flux d'authentification

L'access token est stocké en mémoire React (variable d'état dans `AuthContext`). Ce choix est délibéré : stocker le token dans `localStorage` l'exposerait aux attaques XSS, une vulnérabilité classique du top 10 OWASP. Un script malveillant injecté dans la page pourrait lire `localStorage` mais ne peut pas accéder à une variable JavaScript en mémoire appartenant à un autre contexte.

Le refresh token est stocké dans un cookie avec les attributs `HttpOnly`, `Secure`, `SameSite=Lax` et `path=/api/auth/`. L'attribut `HttpOnly` empêche tout accès JavaScript au cookie. L'attribut `path=/api/auth/` restreint l'envoi du cookie aux seules URLs `/api/auth/refresh/` et `/api/auth/logout/`, évitant qu'il soit transmis sur les requêtes du portail public.

Au chargement de l'application, un appel silencieux à `/api/auth/refresh/` restaure l'access token depuis le cookie, permettant à l'utilisateur de rester connecté sans ressaisir ses identifiants.

2.5.3.2 Contrôle d'accès basé sur les rôles (RBAC)

Chaque endpoint Django est protégé par une classe de permission DRF :

TABLE 2.6 – Matrice de contrôle d'accès

Action	**ADMIN**	**MANAGER**	**ANALYST**	**VIEWER**
Créer une offre	✓	✓		
Modifier une offre	✓	✓		
Voir toutes les offres	✓	✓	✓	
Voir offres publiées	✓	✓	✓	✓
Scorer une soumission	✓	✓	✓	
Exporter PDF	✓	✓	✓	
Gérer les utilisateurs	✓			
Consulter l'audit log	✓			

2.5.3.3 Chiffrement AES-256-GCM

Le chiffrement est appliqué sélectivement aux documents marqués sensibles (propositions financières, contrats). Le chiffrement de tous les fichiers ajouterait une latence inutile sur les pièces jointes anodines.

L'algorithme AES-256-GCM (mode Galois/Counter Mode) garantit simultanément :

- La confidentialité : les données en clair sont inaccessibles sans la clé de 256 bits.
- L'intégrité : le tag d'authentification de 128 bits détecte toute modification du fichier chiffré.

Pour chaque fichier chiffré, un nonce de 12 octets est généré aléatoirement. Le fichier stocké sur disque contient la concaténation : `nonce (12B) || ciphertext || tag (16B)`. La clé de chiffrement (32 octets = 256 bits) est fournie via la variable d'environnement `DOCUMENT_ENCRYPTION_KEY` et n'apparaît jamais dans le code source ni dans le dépôt Git.

2.5.3.4 Diagramme de séquence – Soumission portail public

La soumission via le portail public suit un flux en plusieurs étapes : vérification de l'offre (statut PUBLISHED), contrôle de la deadline, validation des données, création ou récupération du candidat (upsert par email), vérification d'unicité, création de la soumission, upload du document, et notification du responsable assigné.

Ce flux est atomique : en cas d'erreur à l'étape d'upload du fichier, la soumission créée est supprimée pour maintenir la cohérence de la base de données.

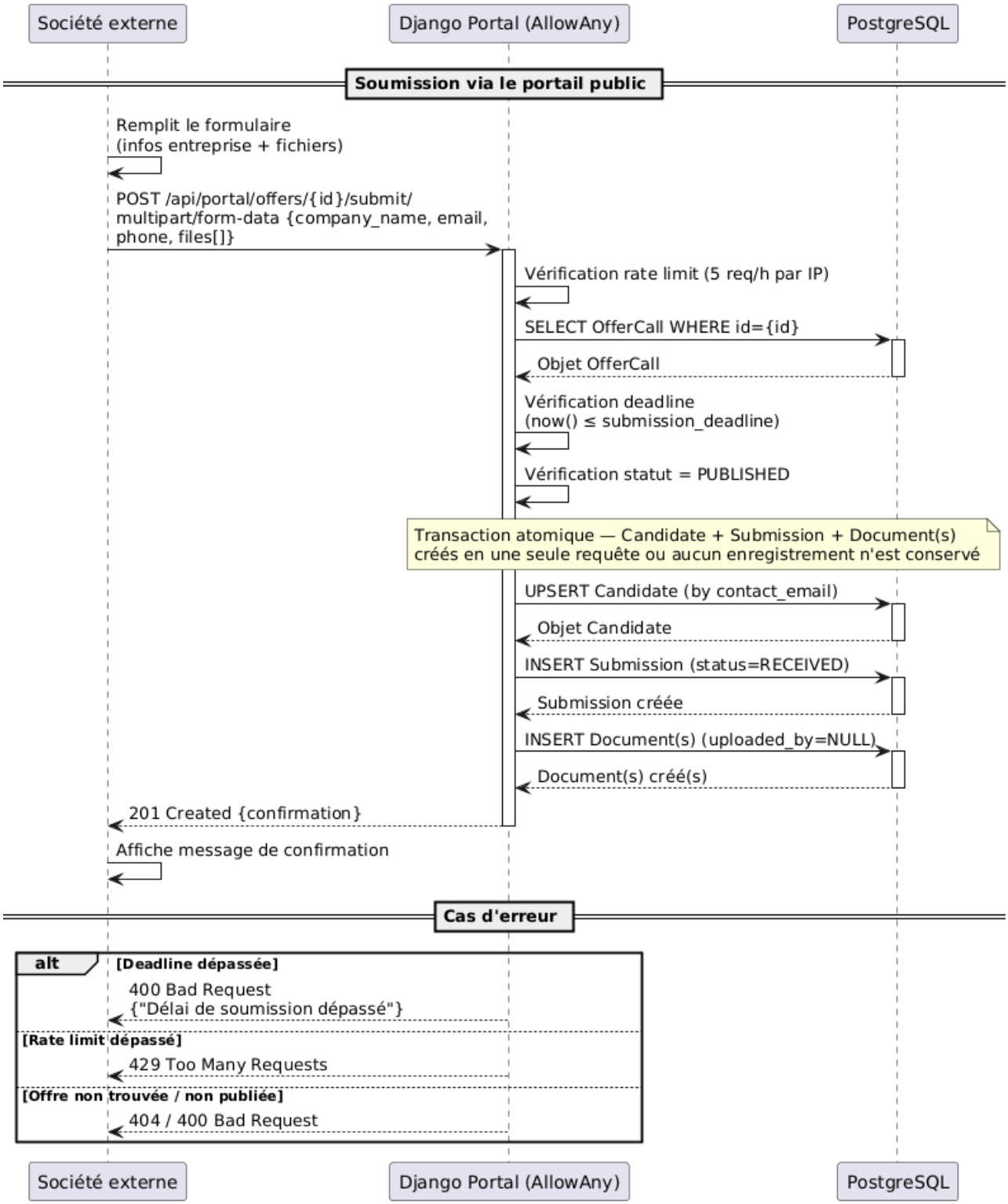


FIGURE 2.7 – Diagramme de séquence : soumission portail public

2.6 Conclusion

Ce chapitre a présenté l'ensemble des décisions de conception qui structurent le système. Les choix technologiques ont été justifiés au regard des contraintes du projet, et la méthodologie Agile adoptée a permis de livrer des fonctionnalités testables à chaque sprint. La modélisation UML a formalisé les interactions entre acteurs et les flux métier, tandis que l'architecture monolithe modulaire offre une séparation claire des responsabilités sans la complexité opérationnelle des microservices. La conception de la sécurité, fondée sur JWT, RBAC et AES-256-GCM, constitue la base sur laquelle repose la réalisation décrite dans le chapitre suivant.

Chapitre 3

Réalisation et Mise en Œuvre

Ce chapitre décrit la concrétisation des choix de conception présentés au chapitre précédent. Il détaille l'environnement de développement, l'implémentation des modules backend et frontend, les interfaces utilisateur réalisées, ainsi que les résultats des tests de validation. L'objectif est de démontrer que la solution développée répond aux exigences fonctionnelles et non-fonctionnelles identifiées en début de projet.

3.1 Environnement de développement

3.1.1 Outils utilisés

Table 3.1 – Outils de développement

Outil	**Version**	**Usage**
Python	3.11	Langage backend
Django	4.2	Framework web backend
Django REST Framework	3.15	API REST
React.js	18	Framework frontend
Vite	5	Bundler frontend
TailwindCSS	3	Styles utilitaires
PostgreSQL	15	Base de données
Docker & Compose	24	Conteneurisation
Nginx	1.25	Proxy inverse, TLS
GitHub Actions	–	Pipeline CI (lint + tests)
VS Code	–	Éditeur de code
Postman	–	Tests manuels de l'API

3.1.2 Structure du projet

Le projet est organisé en deux répertoires principaux (`backend/` et `frontend/`), complétés par la configuration Docker et Nginx. Le backend Django suit une architecture modulaire : chaque domaine fonctionnel est une application Django distincte avec ses propres modèles, vues, sérialiseurs et URLs.

```
appels-offres/
|-- docker-compose.yml
```

```
|-- nginx/
|   |-- nginx.conf
|   `-- certs/         # Certificat SSL auto-sign  (d monstration)
|-- backend/
|   |-- config/        # Settings, urls.py racine, wsgi.py
|   `-- apps/
|       |-- authentication/   # User, JWT, RBAC
|       |-- offers/           # OfferCall, machine     tats
|       |-- candidates/       # Candidate, Submission
|       |-- documents/        # Upload, AES-256-GCM
|       |-- notifications/    # Notification, check_deadlines
|       |-- reports/          # Export PDF (reportlab)
|       |-- audit/            # AuditLog, signaux Django
|       `-- portal/           # Endpoints publics (AllowAny)
|-- frontend/
|   `-- src/
|       |-- contexts/         # AuthContext
|       |-- pages/            # Login, Dashboard, offres, portail...
|       |-- services/         # Wrappers API par domaine
|       `-- hooks/            # useAuth, useNotifications
`-- .github/workflows/ci.yml  # GitHub Actions
```

Listing 3.1 – Structure du projet

3.1.3 Pipeline d'intégration continue

À chaque push sur la branche `main`, GitHub Actions exécute automatiquement :

1. **Lint** : `flake8` vérifie le style et la qualité du code Python (longueur des lignes, imports inutilisés, variables non utilisées).
2. **Tests** : `pytest-django` exécute les tests d'intégration avec une base de données PostgreSQL dédiée au pipeline.

[À INSÉRER — Pipeline CI GitHub Actions — capture d'écran]

FIGURE 3.1 – Pipeline CI GitHub Actions (lint + tests)

3.2 Implémentation du backend

3.2.1 Authentification et RBAC

Le modèle `User` étend `AbstractBaseUser` de Django pour définir le champ `email` comme identifiant principal (et non le nom d'utilisateur). Un champ `role` de type `CharField` avec des choix énumérés (`ADMIN`, `MANAGER`, `ANALYST`, `VIEWER`) définit le rôle de chaque utilisateur.

```python
class User(AbstractBaseUser, PermissionsMixin):
    id = models.UUIDField(primary_key=True, default=uuid.uuid4)
    email = models.EmailField(unique=True)
    full_name = models.CharField(max_length=150)
    role = models.CharField(max_length=10, choices=ROLE_CHOICES, default='VIEWER')
    department = models.CharField(max_length=100, blank=True)
    is_active = models.BooleanField(default=True)
    created_at = models.DateTimeField(auto_now_add=True)
```

Listing 3.2 – Modèle User

Les permissions DRF sont définies comme des classes réutilisables : `IsManagerOrAdmin` (création et modification d'offres), `IsAnalystOrAbove` (lecture de toutes les offres, évaluation), `IsAdminRole` (gestion des utilisateurs, journal d'audit). Ces classes sont appliquées au niveau de chaque vue et centralisées dans `apps/authentication/permissions`.

L'endpoint de connexion génère un access token (durée 15 minutes) retourné dans le corps de la réponse JSON, et un refresh token (durée 7 jours) placé dans un cookie sécurisé. La bibliothèque `djangorestframework-simplejwt` gère la génération, la validation et la révocation des tokens.

3.2.2 Gestion des offres et machine à états

Le modèle `OfferCall` implémente une machine à états explicite. Les transitions autorisées sont définies dans un dictionnaire Python qui associe à chaque statut la liste des statuts atteignables.

```python
ALLOWED_TRANSITIONS = {
    'DRAFT':      ['PUBLISHED', 'CANCELLED'],
    'PUBLISHED':  ['EVALUATION', 'CANCELLED'],
    'EVALUATION': ['AWARDED', 'CANCELLED'],
    'AWARDED':    [],
    'CANCELLED':  [],
}

def can_transition_to(self, new_status):
    return new_status in ALLOWED_TRANSITIONS.get(self.status, [])
```

Listing 3.3 – Machine à états des offres

Chaque transition est un endpoint POST dédié (`/publish/`, `/close/`, `/award/`, `/cancel/`). Cette conception interdit toute modification directe du champ `status` via PATCH, garantissant que la logique de validation est toujours exécutée.

3.2.3 Documents et chiffrement AES-256-GCM

L'upload de documents s'effectue en multipart/form-data. Avant le stockage, le fichier passe par une validation (type MIME dans la liste blanche PDF/DOCX/XLSX, taille inférieure à 10 Mo), puis par le module de chiffrement si le flag `is_sensitive` est activé.

L'algorithme AES-256-GCM garantit à la fois la confidentialité (les données sont illisibles sans la clé) et l'intégrité (le tag d'authentification détecte toute modification). Pour chaque fichier chiffré, un nonce (nombre utilisé une seule fois) de 12 octets est généré aléatoirement, ce qui garantit que deux fichiers identiques produisent des chiffrés différents.

```python
def encrypt_file(data: bytes, key: bytes) -> bytes:
    nonce = os.urandom(12)
    aesgcm = AESGCM(key)
    ciphertext = aesgcm.encrypt(nonce, data, None)
```

```
    return nonce + ciphertext  # nonce (12B) || ciphertext || tag (16B)
```

Listing 3.4 – Chiffrement AES-256-GCM

Le déchiffrement est transparent pour le client : lors du téléchargement, Django détecte `is_encrypted=True`, lit les 12 premiers octets comme nonce, déchiffre le reste, et retourne le fichier en clair dans la réponse HTTP. La clé ne transite jamais en dehors du processus Django.

3.2.4 Portail public

L'application `portal` est isolée : elle ne partage aucune classe de permission ni aucun sérialiseur avec les applications internes. Elle importe uniquement les modèles (`OfferCall`, `Candidate`, `Submission`, `Document`).

La vue `PublicSubmitView` implémente trois protections :

1. **Rate limiting** : décorateur `@ratelimit(key='ip', rate='5/h', block=True)` de la bibliothèque `django-ratelimit` Un script automatisé ne peut pas inonder la base de données. (Dans le contexte de démonstration, ce seuil est volontairement bas ; en production, il serait augmenté.)
2. **Vérification de deadline** : `timezone.now() > offer.submission_deadline` retourne HTTP 400 si la date limite est dépassée.
3. **Unicité** : une société ne peut pas soumettre deux fois une proposition pour la même offre (identifiée par email).

3.2.5 Audit et notifications

Le journal d'audit est alimenté par des appels explicites à `AuditLog.objects.create()` dans chaque vue lors des opérations d'écriture. Chaque entrée enregistre : l'utilisateur (nullable pour le portail), l'action, le type de ressource, son identifiant, les modifications au format JSON et l'adresse IP.

Le scheduler s'exécute dans un conteneur Docker dédié en boucle :

```
while true; do
    python manage.py check_deadlines && sleep 3600 || sleep 60;
done
```

Listing 3.5 – Boucle du scheduler

La commande `check_deadlines` interroge la base de données pour toutes les offres dont la deadline approche (dans les 24 heures) et crée les notifications correspondantes pour les responsables assignés.

3.3 Implémentation du frontend

3.3.1 Gestion de l'authentification

Le contexte `AuthContext` de React centralise l'état d'authentification : l'access token est stocké dans une variable d'état (mémoire), jamais dans `localStorage` ou `sessionStorage`. Au montage de l'application, un appel silencieux à `/api/auth/refresh/` restaure le token depuis le cookie httpOnly si la session est encore valide.

Un intercepteur Axios ajoute automatiquement l'en-tête `Authorization: Bearer <token>` à chaque requête, et gère le rafraîchissement transparent en cas de réponse 401 (token expiré).

3.3.2 Routage protégé par rôle

Les routes React sont enveloppées dans des composants de garde : `PrivateRoute` (authentification requise) et `RoleGuard` (rôle minimum requis). Un utilisateur VIEWER qui tente d'accéder à la page de création d'offre est redirigé vers le tableau de bord.

3.3.3 Portail public

Le portail utilise une instance Axios séparée (`portalApi.js`) sans en-tête `Authorization`. Les pages `/portal` et `/portal/:id` sont accessibles sans connexion et ne partagent aucun état avec l'application interne.

3.4 Interfaces et fonctionnalités

3.4.1 Tableau de bord

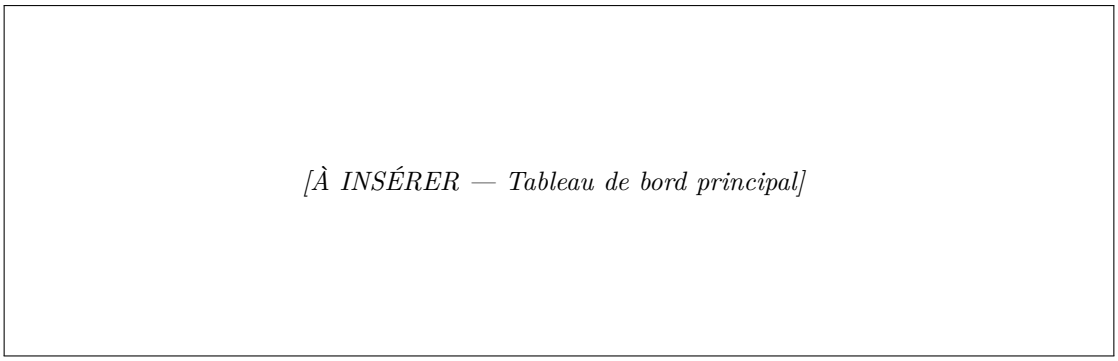


FIGURE 3.2 – Tableau de bord principal

3.4.2 Liste et filtrage des offres

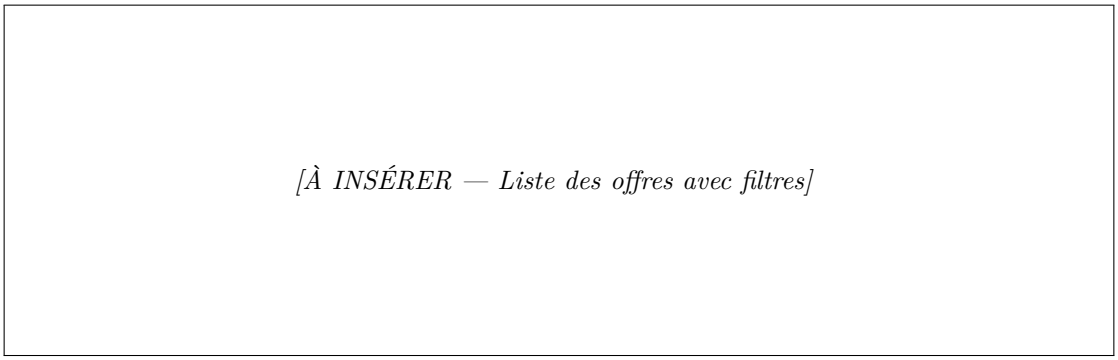


FIGURE 3.3 – Liste des offres avec filtres

La page de liste affiche les offres sous forme de tableau paginé avec filtres par statut, catégorie et recherche textuelle. Des badges colorés signalent l'état de chaque offre (vert : publiée, orange : en évaluation, rouge : annulée).

3.4.3 Détail d'une offre

La page de détail est organisée en onglets : informations générales, soumissions des candidats (avec scores), et documents associés (avec indicateur de chiffrement AES-256).

[À INSÉRER — Détail d'une offre avec onglets]

FIGURE 3.4 – Détail d'une offre avec onglets

[À INSÉRER — Formulaire de création d'offre]

FIGURE 3.5 – Formulaire de création d'offre

3.4.4 Formulaire de création d'offre

3.4.5 Évaluation d'une soumission

3.4.6 Portail public

3.4.7 Journal d'audit

3.4.8 Rapport PDF

[À INSÉRER — Évaluation et scoring d'une soumission]

FIGURE 3.6 – Évaluation et scoring d'une soumission

[À INSÉRER — Portail public : liste des offres]

FIGURE 3.7 – Portail public — liste des offres

[À INSÉRER — Formulaire de soumission publique]

FIGURE 3.8 – Formulaire de soumission publique

[À INSÉRER — Journal d'audit]

FIGURE 3.9 – Journal d'audit

[À INSÉRER — Exemple de rapport PDF généré]

FIGURE 3.10 – Exemple de rapport PDF généré

3.5 Tests et validation

3.5.1 Tests automatisés

Les tests d'intégration couvrent les scénarios critiques du système :

TABLE 3.2 – Couverture des tests automatisés

Module	**Cas testés**
Authentification	Connexion valide, identifiants incorrects, refresh token, déconnexion
RBAC	Accès autorisé ou refusé par rôle sur les endpoints critiques
Offres	Création, transitions d'état autorisées et refusées, filtres
Portail	Soumission valide, deadline dépassée, doublon, fichier invalide
Documents	Upload, téléchargement, détection du chiffrement

Les tests utilisent des fixtures par rôle (`admin_user`, `manager_user`, `analyst_user`, `viewer_user`) et une base de données PostgreSQL dédiée. Chaque test est isolé dans une transaction annulée après exécution. L'ensemble des tests passe au vert sur le pipeline CI (figure 3.1).

3.5.2 Tests manuels

Un jeu de données de démonstration a été créé pour valider manuellement les parcours utilisateur : utilisateurs de chaque rôle, offres à différents stades, candidats et soumissions. Ce jeu a permis de tester le parcours complet : création d'offre → publication → soumission via le portail → évaluation → attribution → export PDF → consultation du journal d'audit.

3.6 Conclusion

Ce chapitre a présenté la mise en œuvre complète du système, de l'environnement de développement jusqu'à la validation par les tests. L'implémentation backend a démontré la robustesse de la machine à états des offres, la transparence du chiffrement AES-256-GCM et l'isolation effective du portail public. Côté frontend, la gestion sécurisée des tokens JWT et le routage par rôle garantissent une expérience utilisateur cohérente avec les exigences de sécurité. Les tests automatisés et le pipeline CI confirment la fiabilité de l'ensemble, et les tests manuels valident les parcours fonctionnels de bout en bout.

Conclusion

Récapitulatif des réalisations

Au terme de ce stage d'un mois, l'application web de gestion des appels d'offres a été développée, testée et déployée dans son intégralité. Les objectifs fixés en début de stage ont été atteints :

- Authentification sécurisée JWT avec cookie httpOnly scopé, contrôle d'accès par rôles (RBAC) sur l'ensemble des endpoints ;
- Cycle de vie complet des appels d'offres (DRAFT → PUBLISHED → EVALUATION → AWARDED) avec machine à états côté serveur ;
- Portail public permettant aux sociétés externes de déposer leurs propositions sans compte, avec rate limiting et vérification des deadlines ;
- Chiffrement AES-256-GCM sélectif des documents sensibles, déchiffrement transparent au téléchargement ;
- Notifications automatiques par le scheduler Docker ;
- Export PDF des synthèses d'offres ;
- Journal d'audit complet sur toutes les opérations d'écriture ;
- Pipeline CI GitHub Actions (lint + tests) actif sur chaque push.

Difficultés rencontrées

3.6.0.0.1 Isolation du portail public La principale difficulté architecturale a été de concevoir le portail public comme une surface réellement isolée de l'API interne. Le problème du cookie de rafraîchissement – qui, sans restriction de chemin, aurait été envoyé sur toutes les requêtes du portail – a nécessité de restreindre le cookie à `path=/api/auth/`, une subtilité non documentée dans la plupart des tutoriels JWT.

3.6.0.0.2 Chiffrement sélectif L'intégration du chiffrement AES-256-GCM a soulevé la question de la gestion des clés : stocker la clé dans le code source ou dans `docker-compose.yml` aurait constitué une faille évidente. La solution par variable d'environnement (`DOCUMENT_ENCRYPTION_KEY`) et l'exclusion des fichiers `.env` du dépôt Git ont résolu ce problème.

3.6.0.0.3 Pipeline CI Les premiers commits ont déclenché des échecs de pipeline liés à des migrations manquantes et des violations de lint. La correction a nécessité de comprendre le flux de migration Django dans un environnement de test isolé.

Compétences acquises

Ce stage a été l'occasion de mettre en pratique et d'approfondir plusieurs compétences :

- Développement d'API REST sécurisées avec Django REST Framework ;

- Sécurité web applicative (OWASP Top 10, JWT, RBAC, chiffrement) ;
- Conteneurisation avec Docker Compose et architecture multi-services ;
- Intégration continue avec GitHub Actions ;
- Conception de systèmes : modèle de données, machine à états, audit.

Perspectives

L'application est fonctionnelle et déployable, mais plusieurs améliorations pourraient être envisagées pour une mise en production réelle :

Certificat SSL valide Remplacer le certificat auto-signé par un certificat Let's Encrypt pour éliminer les avertissements navigateur.

Notifications par email Ajouter l'envoi d'emails (SMTP) en complément des notifications en application.

Rotation des clés AES Implémenter un mécanisme de re-chiffrement des documents lors d'un changement de clé.

Optimistic locking Prévenir les conflits d'édition simultanée sur les offres via un champ de version.

Docker Secrets Remplacer les variables d'environnement par Docker Secrets ou un gestionnaire de secrets dédié (Vault) en production.

À RÉDIGER : paragraphe de clôture personnel — bilan humain, expérience globale du stage, recommandation

Chapitre 4

docker-compose.yml

```yaml
version: '3.9'

services:
  db:
    image: postgres:15
    environment:
      POSTGRES_DB: ${DB_NAME:-offres_db}
      POSTGRES_USER: ${DB_USER:-postgres}
      POSTGRES_PASSWORD: ${DB_PASSWORD:-postgres}
    volumes:
      - postgres_data:/var/lib/postgresql/data
    healthcheck:
      test: ["CMD-SHELL", "pg_isready -U ${DB_USER:-postgres}"]
      interval: 10s
      timeout: 5s
      retries: 5

  backend:
    build: ./backend
    command: >
      sh -c "python manage.py migrate --noinput &&
             python manage.py collectstatic --noinput &&
             python manage.py runserver 0.0.0.0:8000"
    environment:
      SECRET_KEY: ${SECRET_KEY}
      DOCUMENT_ENCRYPTION_KEY: ${DOCUMENT_ENCRYPTION_KEY}
    depends_on:
      db:
        condition: service_healthy

  scheduler:
    build: ./backend
    command: >
      sh -c "while true; do
               python manage.py check_deadlines && sleep 3600 || sleep 60;
             done"
    depends_on:
      db:
        condition: service_healthy
```

```
40
41   frontend:
42     build: ./frontend
43     ports:
44       - "3000:3000"
45
46   nginx:
47     build: ./nginx
48     ports:
49       - "80:80"
50       - "443:443"
51     depends_on:
52       - backend
53       - frontend
54
55 volumes:
56   postgres_data:
```

Listing 4.1 – docker-compose.yml complet

Chapitre 5

Exemple d'entrée AuditLog

Exemple d'enregistrement dans le journal d'audit pour une opération de publication d'une offre :

```
{
  "id": "3fa85f64-5717-4562-b3fc-2c963f66afa6",
  "user": {
    "id": "9b1deb4d-3b7d-4bad-9bdd-2b0d7b3dcb6d",
    "email": "manager@nonedc.ma",
    "full_name": "Karim Benchekroun",
    "role": "MANAGER"
  },
  "action": "UPDATE",
  "resource_type": "OfferCall",
  "resource_id": "7c9e6679-7425-40de-944b-e07fc1f90ae7",
  "changes": {
    "status": "PUBLISHED",
    "published_at": "2025-08-15T09:32:14.000Z"
  },
  "ip_address": "192.168.1.42",
  "timestamp": "2025-08-15T09:32:14.123Z"
}
```

Listing 5.1 – Entrée AuditLog – publication d'une offre

Chapitre 6

Manuel utilisateur

Connexion

Accéder à l'application via le navigateur. Saisir l'adresse email et le mot de passe. Cliquer sur *Se connecter*. En cas d'erreur, vérifier les identifiants.

Créer un appel d'offres

1. Dans le menu latéral, cliquer sur **Offres** puis **Nouvelle offre**.
2. Renseigner le titre, la description, la catégorie, le budget estimatif et les dates limites.
3. Cliquer sur **Enregistrer**. L'offre est créée en statut BROUILLON.
4. Pour la publier, ouvrir le détail de l'offre et cliquer sur **Publier**.

Évaluer les soumissions

1. Ouvrir le détail de l'offre, onglet **Soumissions**.
2. Cliquer sur la soumission à évaluer.
3. Saisir le score technique et le score financier.
4. Cliquer sur **Enregistrer l'évaluation**.

Portail public (sociétés externes)

1. Accéder à `https://[domaine]/portal`.
2. Consulter la liste des appels d'offres ouverts.
3. Cliquer sur une offre pour voir le descriptif complet.
4. Cliquer sur **Soumettre une offre** et remplir le formulaire (coordonnées, numéro d'enregistrement, fichier PDF de la proposition).
5. Conserver le numéro de soumission retourné à titre de référence.

Chapitre 7

Résultats du pipeline CI

Le pipeline s'exécute en deux étapes séquentielles :

1. `flake8 .` – vérification du style Python (0 erreur)
2. `pytest -ds=config.settings` – 12 tests, 0 échec, 0 saut